
NONPROFIT AI RESOURCES · MANDY HATHAWAY CONSULTING

AI Privacy for Nonprofits

Protecting client confidentiality when you use AI tools

Mandy Hathaway Consulting · mandyhathaway.com · AI Ethics & Technology Consulting

Privacy and security are related but different. Security is about keeping data safe from unauthorized access. Privacy is about controlling how information is collected, used, and shared — and making sure the people it belongs to have some say in that. When a nonprofit brings AI tools into its work, both matter, but privacy raises a distinct set of questions that security alone does not answer.

Your organization almost certainly has existing privacy obligations. Funder agreements, state law, professional ethics standards, and the basic trust your clients place in you all create expectations about how their information is handled. AI does not suspend those obligations. It creates new ways to inadvertently violate them.

The people your organization serves did not consent to having their information processed by an AI

company. That gap between what clients expect and what AI tools do is where privacy risk lives.

Security vs. privacy: why the difference matters

A tool can be perfectly secure and still create a privacy problem. If a case manager pastes a client's intake notes into an AI writing assistant to draft a progress report, no one hacked anything. The data traveled over an encrypted connection to a legitimate vendor's servers. But the client did not agree to that, probably does not know it happened, and depending on your jurisdiction and your program agreements, it may not have been permitted.

Security questions ask: could someone unauthorized get this data? Privacy questions ask: should this data be here at all, and does the person it belongs to know and agree?

For nonprofits working with vulnerable populations, this is a meaningful distinction. A security breach is an event you can investigate and report. A privacy failure can be ongoing and invisible — staff routinely using AI tools with client information in ways that were never disclosed or consented to.

What your clients likely expect

When someone shares personal information with your organization, they typically expect it will be used to serve them, held by your staff, and not disclosed to outside parties without their knowledge. Most clients do not have a detailed mental model of what happens to their data. They are operating on trust.

AI tools are outside parties. Even if a vendor's privacy policy is strong and their data handling is responsible, routing client information through their

systems is a disclosure. Whether it is a permitted disclosure under your program agreements, your funder requirements, or applicable law depends on your specific situation.

IF YOUR ORGANIZATION HANDLES HEALTH INFORMATION

HIPAA applies when you are a covered entity or business associate handling protected health information. Many disability-services and employment-services nonprofits fall into this category. Using a cloud AI tool to process PHI without a Business Associate Agreement in place is a compliance violation, not just a best practice concern. Check with your compliance officer or legal counsel before using AI with any health-adjacent client records.

Where privacy risk actually shows up

The most common privacy failures in nonprofit AI use are not dramatic. They are ordinary work habits applied to tools that were not designed with your clients in mind.

HIGH RISK SCENARIOS

Pasting case notes into an AI writing tool to draft reports

Uploading intake forms or client files to summarize them

Using AI chat tools to get advice on a specific client situation

Having AI transcribe or summarize meetings where client details were discussed

LOWER RISK SCENARIOS

Using AI to draft general templates, policies, or communications

Asking AI to help with grant writing using anonymized program data

Using AI for internal research, training materials, or administrative writing

Using AI to analyze aggregated, de-identified program outcome data



The pattern is consistent: risk goes up when real client information enters the AI tool, and down when the work stays general, anonymized, or administrative.

What consent looks like in an AI context

For most nonprofits, obtaining AI-specific consent from clients is not currently standard practice. That does not mean it is not worth thinking about, particularly if your organization is expanding AI use significantly.

Some considerations as this landscape develops:

1 Review your existing intake and consent forms.

Many older forms do not contemplate AI use. If your forms describe how client information will be used and shared, AI tool use may not be covered. A legal or compliance review of your standard consent language is worth doing before AI use becomes widespread.

2 Know what your funder agreements say.

Government contracts and foundation grants often include data use restrictions. Some specify that client information may not be shared with third parties in ways that include AI vendors. Check your agreements before assuming general AI use is permitted.

3 Consider disclosure even where consent is not legally required.

Your clients trust you. Letting them know if and how AI is used in your work, even in general terms, is consistent with that relationship. Some organizations are beginning to add a brief AI disclosure to their intake materials.

Building privacy into your AI workflow

The most practical way to protect client privacy is to make anonymization a habit before any client-adjacent information touches an AI tool. This does not require a major process overhaul. It requires a clear mental filter that staff apply consistently.

THE ANONYMIZATION FILTER

Before using an AI tool with any information that came from or about a client, ask: if someone outside my organization read this input, could they identify the person? If yes, remove or generalize the identifying details before proceeding. Names, locations, dates, specific diagnoses, employer names, and case ID numbers can all serve as identifiers depending on context.

Beyond the individual habit, organizations should think about three structural questions:

1 Which tools are approved for which types of work?

Not every AI tool needs to be approved for every use case. Having a clear list of what is permitted with what types of information reduces the cognitive load on staff and creates accountability.

2 Are vendor agreements in place?

For any tool used with sensitive information, a data processing agreement should specify how the vendor handles your data, whether they train on it, and what their breach notification obligations are to you.

3 Who reviews new tools before they are adopted?

Shadow IT — staff using unapproved tools on their own — is a real risk in every organization. A lightweight approval process does not need to be burdensome, but someone should be looking at new tools before they become embedded in workflows.

A practical starting point

If your organization is early in thinking through AI and privacy, a one-page internal guidance document is more useful right now than a comprehensive policy. It should answer three questions for staff: What tools are approved? What information can and cannot go into those tools? Who do I ask if I am unsure?

That document does not need to be perfect. It needs to exist, be communicated, and be updated as your practice evolves. The organizations that handle AI privacy well are not the ones with the most sophisticated policies. They are the ones that started the conversation early and kept it going.

Mandy Hathaway

AI Ethics & Technology Consulting for Nonprofits

mandyhathaway.com · [Book a call](#)